

ITINS Exam Note - May 2026 - 2108121

INTRODUCTION

Threat: potential for violation of security; *vulnerability*: way by which loss can happen; *attack*: assault on security system.
Low impact: limited effects, degradation in functions, minor harm; *moderate impact*: serious effect, significant degradation in functions, significant harm; *high impact*: catastrophic effect, severe degradation, inability to perform 1 primary function, catastrophic harm to individuals, death.

White hat: ethical, legal; *grey hat*: commit crimes, unethical, not for personal gain; *black hat*: unethical, criminals, for personal gain.

Policy enforcement: *Secure*: reachable entirely in secure states with buffer; *precise*: reachable entirely in secure, no buffer; *board*: some reachable in secure, some not.

THREATS, RISK ASSESSMENT & TRUST

Trust: assumption system is secure; *assurance*: degree of confidence that a system or service meets requirements.

Risk likelihood something bad happens & causes harm. *Ass. Steps*: 1. identify risks; 2. analyse likelihood; 3. formulate solutions for reducing; 4. continuously monitor. *Risk accepted*: low value, low frequency, low impact.

Single Loss Expectancy = Assets Value × Exposure Factor. $SLE \times \text{Annual Rate Occurrence} = \text{Annual Loss Expectancy}$.

TCSEC (Orange Book): C1 discretionary protection; C2 controlled access protection; B1 labelled security protection; B2 structured protections; B3 security domains; A1 verified protection.

ITSEC E1 informal architecture, security target defined & tested; E2 informal descr. design, config control; E3 correspondence between code & sec. target; E4 formal model sec. pol. structured design, vulnerability analysis; E5 code matches design, code vuln. analysis; E6 formal architecture, formal design map to sec. pol., executable maps to source.

FIREWALLS

Ports: 20, 21 FTP; 22 SSH; 23 Telnet; 25 SMTP (send email); 52 DNS; 80 HTTP; 110 POP3 (col. email); 143 IMAP (col. email); 443 HTTPS. >1024 dynamically assigned. <1024 statically assigned to appl. Max no. 16383.

Routed mode: border between 2 networks, L3 NAT boundary; *Transparent mode*: between two existing routers, no NAT boundary, no IP altering.

Cisco Scenarios: *Small Branch*: 2 VLANs inside & outside; *Small Business*: 3 VLANs inside, outside, DMZ; *Enterprise*: corp hq, 2 remote wrks. IPsec VPN, ASA fw at boundaries of 3x network.

INTRUSION {DETECTION/PREVENTION} SERVICE

Network Intrusion: 1. reconnaissance; 2. access; 3. elevate; 4. root kit; 5. utilise.

IDS before IPS. IDS only observe, IPS take action. IPS introduce slight delay when in-line.

IDS deploy where traffic go from one layer to another. IPS deploy in-line at border between diff. networks. IDS & IPS not mutex.

Detection rules = signatures, like AV signatures. *Atomic* 1 packet; *composite* many packets.

AUTHENTICATION, AUTHORISATION AND ACCOUNTING

Kerberos: User contacts Auth. Server (within Key Distribution Centre). AS responds with encrypted Ticket Granting Service Ticket. User sends TGT to TGS. TGS returns encrypted service ticket to user. User uses service ticket to access network service.

Kerberos v5: separate subkey for each session; authen. uses subkeys; authen.fwd. (ie print server can access email server on users behalf etc); realm hierarchies; multiple encryption schemes.

Administrative Domains: X.500 series of standards; X.511 defines standard operations

LDAP is simplified X.500; LDAP uses TCP

IPSEC

Components: Security Protocol (Authentication Header or Encapsulating Security Payload); key management (Internet Key Exchange); Cryptographic Algorithms.

Packets: Header, Payload, Trailer.

AH: hashed message and message transmitted in plain sight; hash recomputed on receiving end to validate authenticity.

ESP encrypted message transmitted; authenticity optional using MD5 or SHA to hash message. Encryption always performed first.

Modes: *Transport*: security for transport layer and above; protect payload; original IP in plaintext; ESP used between hosts where encrypted TCP session forms. *Tunnel*: security for entire original IP packet; encrypted orig. packet and encapsulated in another; ESP tunnel formed in site-to-site between secure gateways.

authenticated, {encrypted}

Orig packet: IP header, TCP header, data

AH, Tra: IP header, AH header, TCP header, data

AH, Tun: New IP header, AH header, IP header, TCP header, data

ESP, Tra: IP header, ESP header, {TCP header, Data, ESP trailer}, ESP auth

ESP, Tun: New IP header, ESP header, {IP header, TCP header, Data, ESP trailer}, ESP auth

Security Associations: one-way sender-receiver relationship; defines protocol, mode, encryption or hashing, keys & key lifetimes, SA lifetime.

IKE: R1 & R2 negotiate IKE phase 1 session: ISAKMP policy, DH key exchange, verify peer identity; R1 & R2 negotiate IKE phase 2 session: IPsec policy; information exchanged via tunnel; tunnel terminated.

TRANSPORT LAYER SECURITY & VIRTUAL PRIVATE NETWORK

TLS: C: ClientHello; S: ServerHello; S: Certificate, ServerHelloDone; C: ChangeCipherSpec, Finished; S: ChangeCipherSpec, Finished.

VPN: Remote access: IPsec or SSL, user initiated, from client to server. Site-to-Site: VPN gateway encapsulates all outgoing traffic, and decrypted on receiving site, IPsec.

MPLS

between layer 2 and 3 of OSI. Maps IP addresses to fixed-length labels. Interfaces with RSVP and OSPF.

Shim: between link layer header & network layer header. Generic format: 20 bits label; 3 experimental bits (used as class of service); 1 bottom of stack; 8 TTL.

Components: Label Edge Router (edge of MPLS, assign and remove labels); Label Switching Router (high speed router in core of MPLS network); Forward Equivalence Class (representation of group of packets sharing same requirements, pkts assigned to FEC once when they enter network); Label Switched Path (path is representation of FEC, established before routing starts. Either hop-by-hop (LSR independently selects next hop) or ingress LSR specifies nodes).

Operation: label creation and distribution; table creation at each router (making entries in label information base); label-switched path creation (done in reverse direction to entries in LIBs); label insertion / table lookup; packet forwarding.

AUDITING

Types: Process, Product, System

Syslog 0 emergency; 1 alert; 2 critical; 3 errors; 4 warnings; 5 notifications; 6 informative; 7 debug.

SNMP: v1: connectionless, community facility (authentication, access policy, proxy); v2 connection-oriented; v3 defines security to be used with v1 or v2 through user-based security model. Data secured using view-based access control model (defines access control policy)

WI-FI

802.11: a 54M@5G; b 11M@2.4G; g 45M@2.4G; n(4) 600M@2.4,5G; ac(5) 6.933G@5G; ax(6) 9.6078G@2.4,5G; d regulatory domains; e QoS; f IAPP; g DSS & TPC; i security; j Japan 5GHz; k measurements

Attacks: Reconnaissance; Rogue AP; WEP bit flipping; DoS; WLAN Jack

WEP: single shared key between AP and all devices.

Authen. & Assoc.: Probe, Authentication, Association. S1: Unauth. & Unassoc.; S2: Auth. & Unassoc.; S3: Auth. & Assoc.

Open Auth.: On success, client & AP: Auth Algorithm No: 0; Authn Trans. Seq. No.: 1; AP only: Status Code: 0

EAP Process: EAP supplicant associates with AP; AP blocks all requests to LAN; client provides login credentials, sent to RADIUS; client auth. RADIUS server; RADIUS server auth. client; RADIUS server & client derive unicast WEP keys; RADIUS server delivers unicast WEP key to AP; AP delivers broadcast WEP key encrypted with unicast WEP key to client; client and AP activate WEP and use keys for transmission.

WLC Topology: Central switching: WLC switches all WLC traffic; Central vs. Local switching: branch site switch does local switching, all other traffic sent over WAN link to HQ for WLC switching. APs have to contact WLC over Layer 3.